Path Traversal — Acceso no autorizado a archivos del sistema

1. Descripción

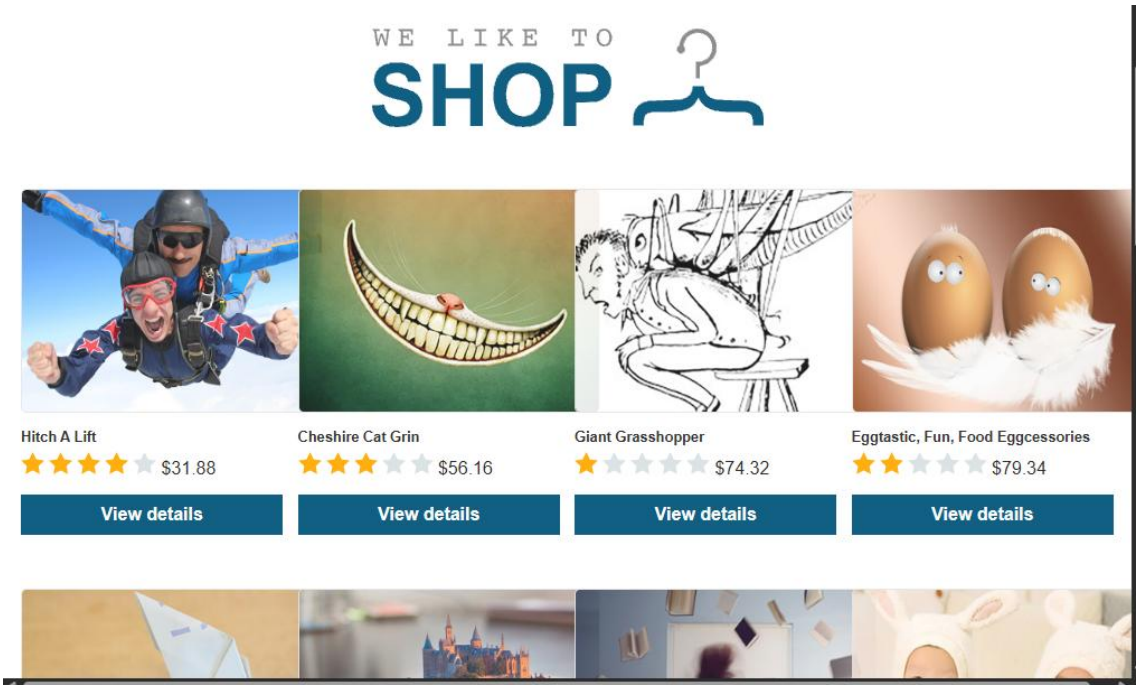
Se identificó una vulnerabilidad de tipo Path Traversal en un laboratorio de PortSwigger Web Security Academy. La aplicación carga imágenes mediante el endpoint `/image`, utilizando el parámetro `filename`.

Durante el análisis de la respuesta de `GET /product?productId=1`, se identificó una referencia a una imagen con la ruta `/image?filename=46.jpg`.

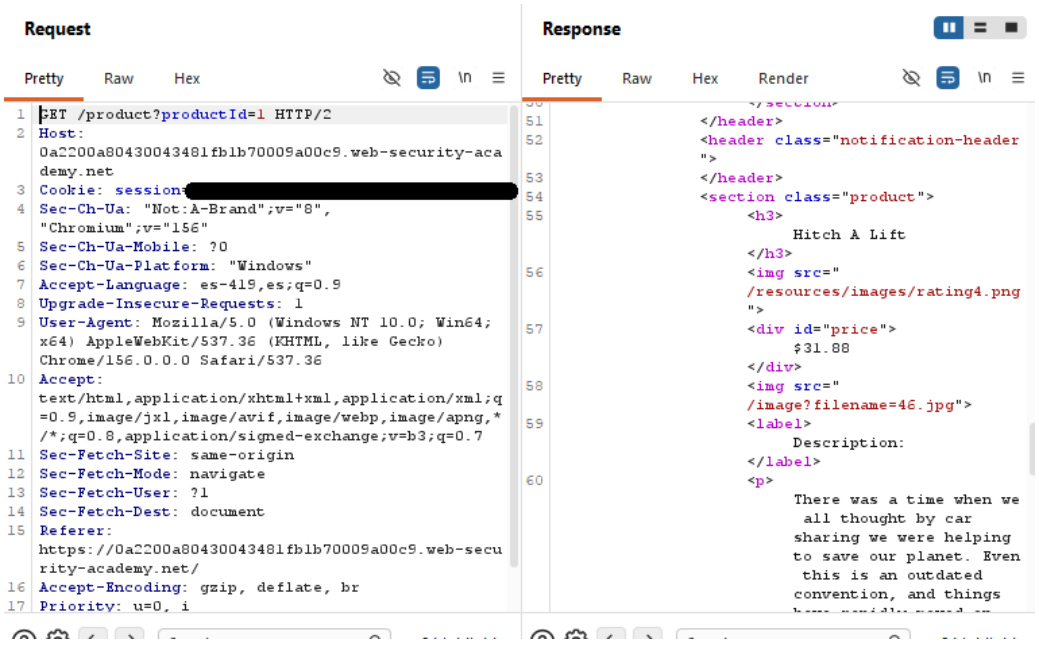
Posteriormente, se modificó el valor del parámetro `filename` para comprobar si la aplicación permitía salir del directorio previsto y acceder a archivos del sistema. La prueba permitió verificar la vulnerabilidad en el entorno controlado del laboratorio.

2. Evidencia

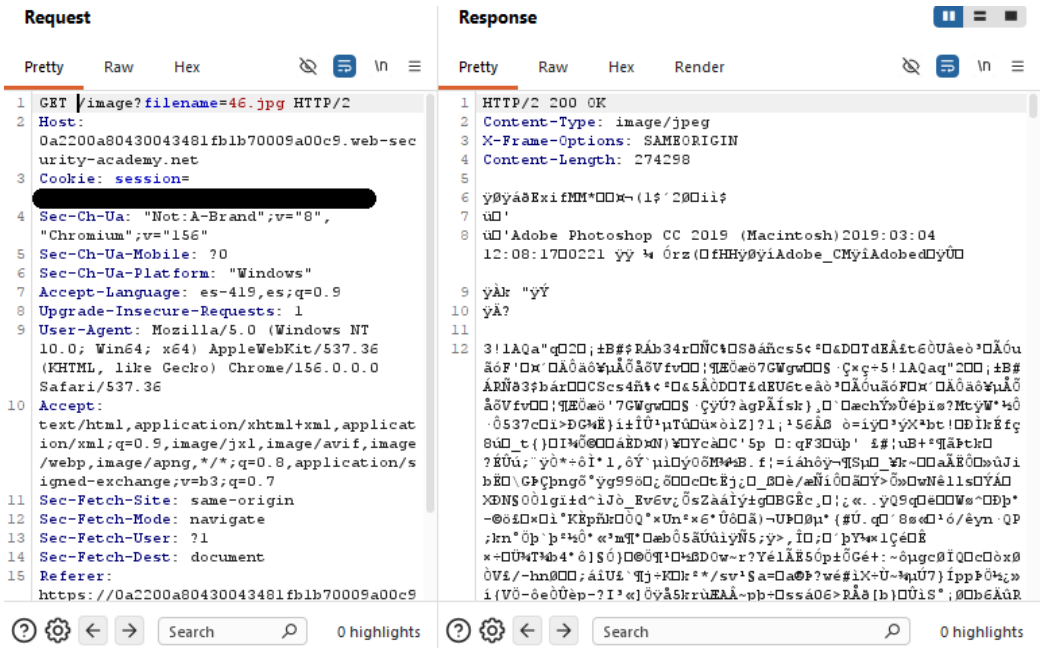
- **Evidencia 01:** página inicial del laboratorio.



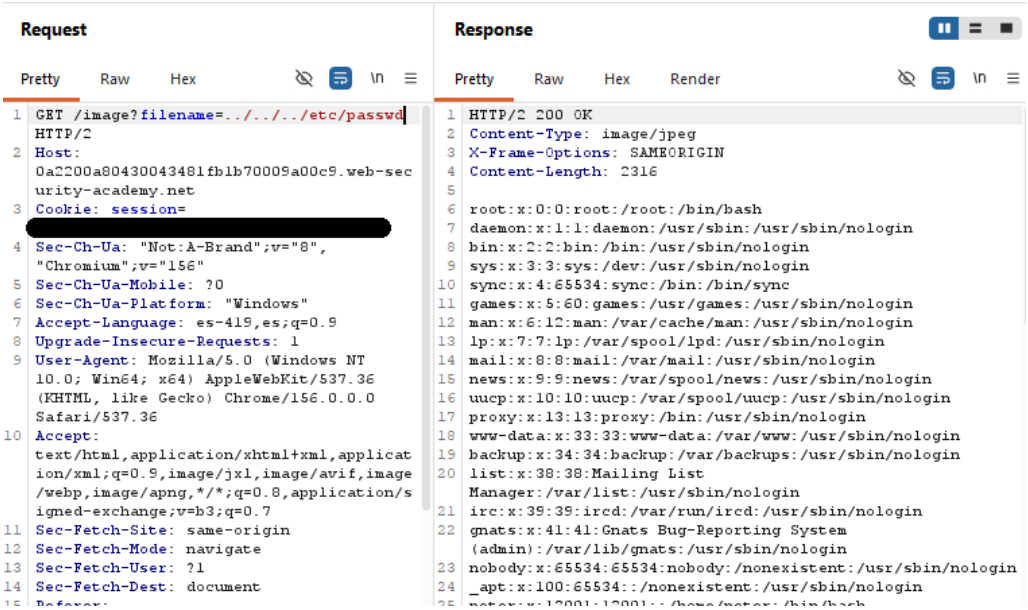
- **Evidencia 02:** respuesta de la aplicación donde se identifica el parámetro utilizado para cargar la imagen.



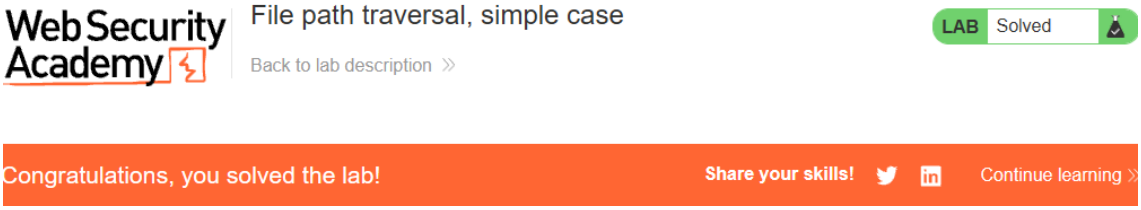
- **Evidencia 03:** petición original de la imagen y respuesta del servidor.



- **Evidencia 04:** petición modificada y respuesta obtenida durante la prueba de Path Traversal.



- **Evidencia 05:** confirmación de que el laboratorio fue resuelto.



Las capturas se encuentran en la carpeta `evidencias/`.

3. Impacto

- **Confidencialidad:** potencialmente alta, si un atacante puede leer archivos sensibles accesibles por el proceso de la aplicación.
- **Integridad:** no se demostró modificación de archivos.
- **Disponibilidad:** no se demostró una afectación directa.

El impacto real depende de los archivos accesibles, los permisos del proceso y las restricciones del entorno.

4. Causa raíz

La aplicación no restringe adecuadamente las rutas de archivo proporcionadas mediante el parámetro `filename`. Esto puede permitir que una entrada manipulada incluya secuencias de recorrido de directorios y apunte fuera del directorio de imágenes previsto.

5. Remediación

- Evitar utilizar directamente rutas proporcionadas por el usuario.

- Asociar identificadores permitidos con archivos del servidor.
- Canonicalizar y validar las rutas antes de acceder a los archivos.
- Restringir el acceso al directorio autorizado y comprobar que la ruta final permanezca dentro de él.
- Ejecutar la aplicación con privilegios mínimos.
- Incorporar pruebas de regresión para entradas que intenten recorrer directorios.

6. CVSS aproximado

Estimación provisional: 6.5 — Medium

Vector orientativo: `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N`

Esta estimación supone que la lectura de archivos requiere una sesión autenticada y que puede exponerse información sensible. Debe revisarse según las condiciones reales de explotación y el impacto demostrado.

7. Prioridad

Alta para evaluación y corrección, si se confirma que la vulnerabilidad permite leer archivos sensibles fuera del directorio autorizado. La prioridad definitiva debe ajustarse a la exposición real y a la sensibilidad de los archivos accesibles.

8. Entorno y herramientas

- **Plataforma:** PortSwigger Web Security Academy.
- **Herramienta:** Burp Suite Repeater.
- **Endpoint analizado:** `/image`.
- **Parámetro:** `filename`.

9. Resultado

La vulnerabilidad se verificó en un entorno educativo autorizado. Las capturas adjuntas documentan el descubrimiento del parámetro, la petición original, la prueba modificada y la resolución del laboratorio.

Este informe describe una práctica de seguridad web y no una evaluación de un sistema de producción.